MAGNETAR LEGAL AUDIT

EXECUTIVE SUMMARY

The Data Processing Addendum contains several clauses that pose significant legal and financial risks to the Customer, including delayed breach notifications beyond GDPR's 72-hour requirement, unrestricted international data transfers without mandated safeguards, and indefinite data retention. Liability exclusions for subprocessors and audit limitations further weaken the Customer's enforcement capabilities. Immediate revisions are essential to ensure compliance with GDPR and the EU AI Act, thereby mitigating potential regulatory penalties and reputational harm.

COMPLIANCE SCORE: 40/100

CRITICAL FINDINGS

[HIGH] Violation

Clause: "5.2 Security Standard (Red-Flag Clause). Provider may change security measures at any time, and Customer agrees such changes may reduce security provided they are "commercially reasonable.""

Why: This clause permits unilateral reduction of security measures by the Processor, conflicting with GDPR Article 5(1)(f) which mandates appropriate technical and organisational measures to ensure data security. The vague term "commercially reasonable" fails to guarantee adequate protection against unauthorized or unlawful processing, accidental loss, or damage.

Correction: Provider shall implement and maintain appropriate technical and organisational security measures that meet or exceed industry standards and shall not reduce security measures without prior written consent from Customer. [Source: https://www.exabeam.com/explainers/gdpr-compliance/gdpr-article-5-key-principles-and-6-compliance-best-practices/]

[CRITICAL] Violation

Clause: "6.4 Subprocessor Liability (Red-Flag Clause). Provider is not liable for Subprocessor acts once Customer has "general authorisation.""

Why: Under GDPR Article 28(3) and supported by authoritative guidance, the Processor remains fully liable for all acts and omissions of subprocessors. Excluding liability for subprocessors breaches GDPR obligations and exposes the Controller to unmitigated risks.

Correction: Provider remains fully liable for all acts and omissions of its subprocessors and shall ensure subprocessors comply with the same data protection obligations as set out in this DPA. [Source: https://www.autoriteitpersoonsgegevens.nl/en/themes/basic-gdpr/gdpr-basics/processing-agreement]

[CRITICAL] Violation

Clause: "7.2 Transfer Mechanism (Red-Flag Clause). Customer agrees that transfers are permitted without Standard Contractual Clauses or any other safeguards if Provider determines safeguards are "not required.""

Why: GDPR Chapter V requires that international transfers outside the EEA/UK occur only with appropriate safeguards such as Standard Contractual Clauses or adequacy decisions. Allowing unilateral determination by Provider violates these mandatory requirements and risks unlawful data transfers.

Correction: Provider shall only transfer Personal Data outside the EEA/UK where appropriate safeguards are in place, such as Standard Contractual Clauses, or where an adequacy decision applies, and shall inform Customer prior to any such

transfer. [Source: https://www.alston.com/ja/insights/publications/2023/05/finalized-guidelines-on-data-transfers-explained]

[HIGH] Violation

Clause: "9.1 Provider will notify Customer of a Personal Data Breach within 10 business days after becoming aware."

Why: GDPR Article 33 mandates breach notification to the Controller without undue delay and, where feasible, within 72 hours. A 10 business day notification period is excessive and non-compliant, potentially leading to regulatory sanctions.

Correction: Provider shall notify Customer of any Personal Data Breach without undue delay and, in any event, within 72 hours of becoming aware of the breach. [Source: https://www.exabeam.com/explainers/gdpr-compliance/gdpr-article-5-key-principles-and-6-compliance-best-practices/]

[HIGH] Violation

Clause: "10.2 Retention (Red-Flag Clause). Provider may retain Personal Data indefinitely where it is "useful for improving services" or "for internal analytics.""

Why: GDPR Article 5(1)(e) requires personal data to be kept no longer than necessary for the purposes of processing. Indefinite retention without clear justification violates the storage limitation principle and increases risk of data misuse.

Correction: Provider shall delete or return Personal Data promptly after the end of the subscription term unless retention is required by law or agreed for a limited, specified period with Customer's consent. [Source: https://www.exabeam.com/explainers/gdpr-compliance/gdpr-article-5-key-principles-and-6-compliance-best-practices/]

[MEDIUM] Violation

Clause: "11.2 Customer may audit no more than once every 36 months."

Why: Restricting audits to once every 36 months may impede the Controller's ability to verify Processor compliance effectively, especially in high-risk scenarios, conflicting with GDPR accountability and oversight requirements.

Correction: Customer may conduct audits at reasonable intervals, including more frequently than once every 36 months, upon reasonable notice and during normal business hours.

[MEDIUM] Violation

Clause: "12.1 If there is a conflict, the MSA controls."

Why: Data protection provisions in a DPA must prevail over conflicting terms in the Master Service Agreement to ensure GDPR compliance. Allowing the MSA to control may undermine data protection obligations and regulatory compliance.

Correction: In the event of any conflict between this DPA and the Master Service Agreement, the terms of this DPA shall prevail with respect to data protection matters.

[CRITICAL] Violation

Clause: "13.2 Automated Decisions (Red-Flag Clause). Customer authorises Provider to make automated decisions that produce legal or similarly significant effects on Data Subjects, without requiring human review."

Why: The EU AI Act and GDPR Article 22 restrict automated decision-making producing legal or significant effects without human intervention unless strict safeguards are implemented. This clause violates transparency, fairness, and human oversight

requirements, exposing the Controller to regulatory risk.

Correction: Provider shall not perform automated decision-making producing legal or similarly significant effects on Data Subjects without explicit Customer consent and ensuring human review and appropriate safeguards as required by applicable law.
